

北极星安全与连续性手册

文档编号 NP-SEC-2027-03 | 正式版 2.0 | 2027-03-01 生效

1. 适用范围与数据分级

本手册适用于北极星计划的平台元数据、知识内容、会话、工作流和审计记录。公开级数据可对外发布；内部级数据只能在项目成员之间共享；机密级数据只允许经授权岗位访问；受限级数据包含凭据、跨租户标识、未脱敏个人信息和安全取证材料。

受限级数据不得进入普通工单、聊天群、模型提示词或前端日志。机密级资料可以进入获准的租户知识库，但必须保留来源、权限和删除记录。数据级别由资料所有者提出，安全负责人确认；无法判断时按更高一级处理。

文档标题中出现“公开”不自动改变级别，必须以平台登记的分类为准。模型生成的摘要继承其最高来源级别，不能因为摘要更短就降低分类。

章节检查提示：区分正式规则、旧版值、服务运维目标与安全恢复目标。

2. 身份、访问与加密

生产访问采用最小权限。Owner 管理租户与高风险配置，Editor 维护授权范围内的知识、员工和工作流，Viewer 只能读取与使用。跨租户资源 ID 即使格式合法也必须返回拒绝，不能通过错误差异确认资源是否存在。

API Key

只保存在后端受控配置，不进入浏览器、普通日志、审计元数据或知识文档。传输使用 TLS，备份使用 AES-256-GCM 认证加密。恢复密钥与备份文件分开保管，任何单一保管人不能同时取得两者。

登录会话撤销后必须立即失效。服务间请求使用独立凭据，不能复用用户 Cookie。紧急访问最长开放 60 分钟，到期自动收回，并在下一个工作日由安全负责人复核。

章节检查提示：区分正式规则、旧版值、服务运维目标与安全恢复目标。

3. 安全事件响应

疑似泄漏、越权或凭据暴露后，发现人应在 10 分钟内通知安全值班组。主事件频道代号为 SEC-ALPHA；普通业务群只能发布脱敏状态，不得粘贴请求正文。值班组先冻结相关访问，再保存请求 ID、时间范围、操作者和脱敏轨迹。

确认跨租户泄漏属于 P0。仅引用缺失且未发现越权时按运维影响定级，通常是 P1。安全定级可以高于服务定级。对外沟通由事件负责人统一发布，工程师不得自行承诺影响范围或删除证据。

事件关闭前要验证凭据轮换、访问撤销、受影响租户通知、审计链连续和补救任务。临时缓解不等于关闭；若根因仍未修复，状态只能是已缓解。

章节检查提示：区分正式规则、旧版值、服务运维目标与安全恢复目标。

4. 备份与灾难恢复目标

平台 MySQL 的目标为 RPO 24 小时、RTO 120 分钟；知识库文档内容同样采用 RPO 24 小时、RTO 120 分钟。订单索引属于单独的数据域，目标更严格，为 RPO 15 分钟、RTO 60 分钟。会话流式事件允许从持久摘要重建，不单独承诺零丢失。

2027 年 2 月的草案曾把知识内容写成 RPO 12 小时、RTO 90 分钟，该值在容量演练后被废止。2027 年 3 月 1 日生效的正式值是 RPO 24 小时、RTO 120 分钟。检索回答必须采用正式值，并在用户询问旧值时说明其已废止。

恢复完成不能只看容器健康。必须从正式页面登录，验证租户、模型配置、知识库、数字员工、历史会话、工作流和审计链；还要执行已知事实、跨文档和无答案三类检索。任何租户归属不一致都视为恢复失败。

章节检查提示：区分正式规则、旧版值、服务运维目标与安全恢复目标。

5. 第三方、例外与审计

阿里百炼和 RAGFlow 是获准依赖，但获准不表示可以发送任意数据。模型请求只包含完成当前任务所需的最小上下文，受限级数据默认禁止出站。新增第三方必须记录地区、数据用途、保留、删除、失败语义和退出方案。

安全例外必须包含申请人、业务理由、影响范围、补偿控制和到期时间。没有到期时间的例外无效。到期前未续期则自动恢复正式规则。例外不能取消租户隔离、凭据脱敏或审计记录。

本手册的唯一检索标记是 SEC-LANTERN-582。它用于确认安全与连续性手册被召回；回答服务故障首次响应时间时应引用运维手册，而不是根据本手册的安全通知时限推断。

章节检查提示：区分正式规则、旧版值、服务运维目标与安全恢复目标。